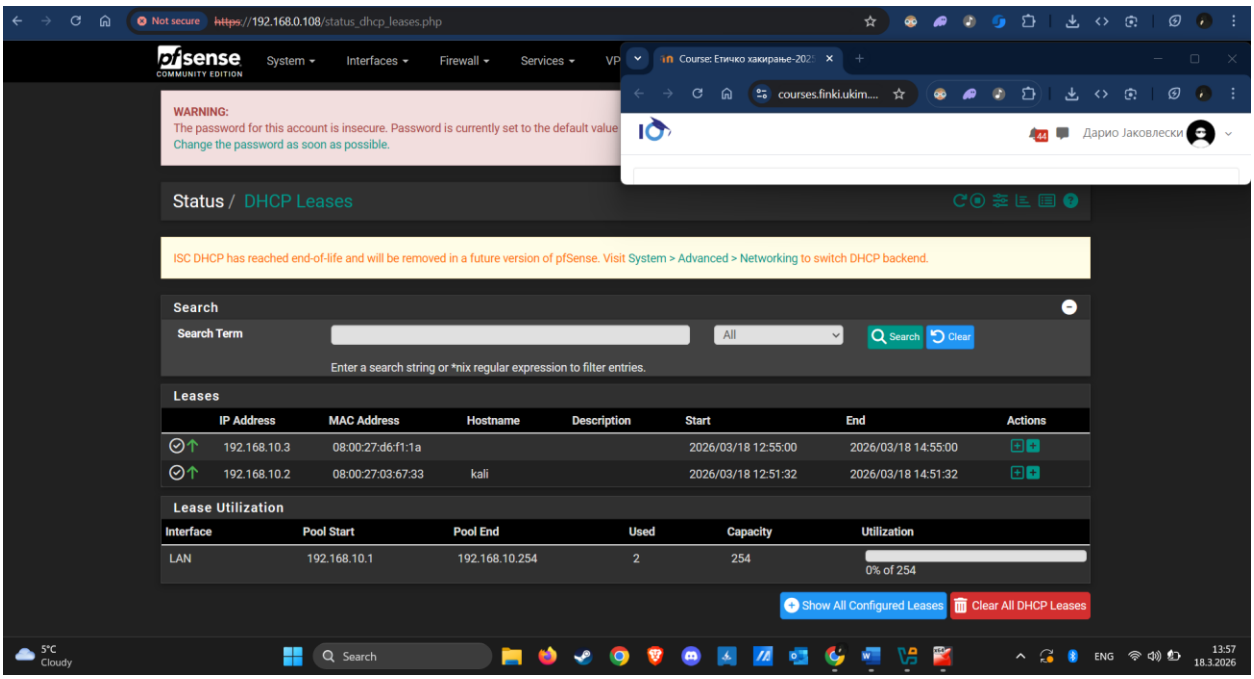
Лабораториска вежба 2 – DHCP & ARP Spoofing	Име и презиме Дарио Јаковлески	Индекс 222015

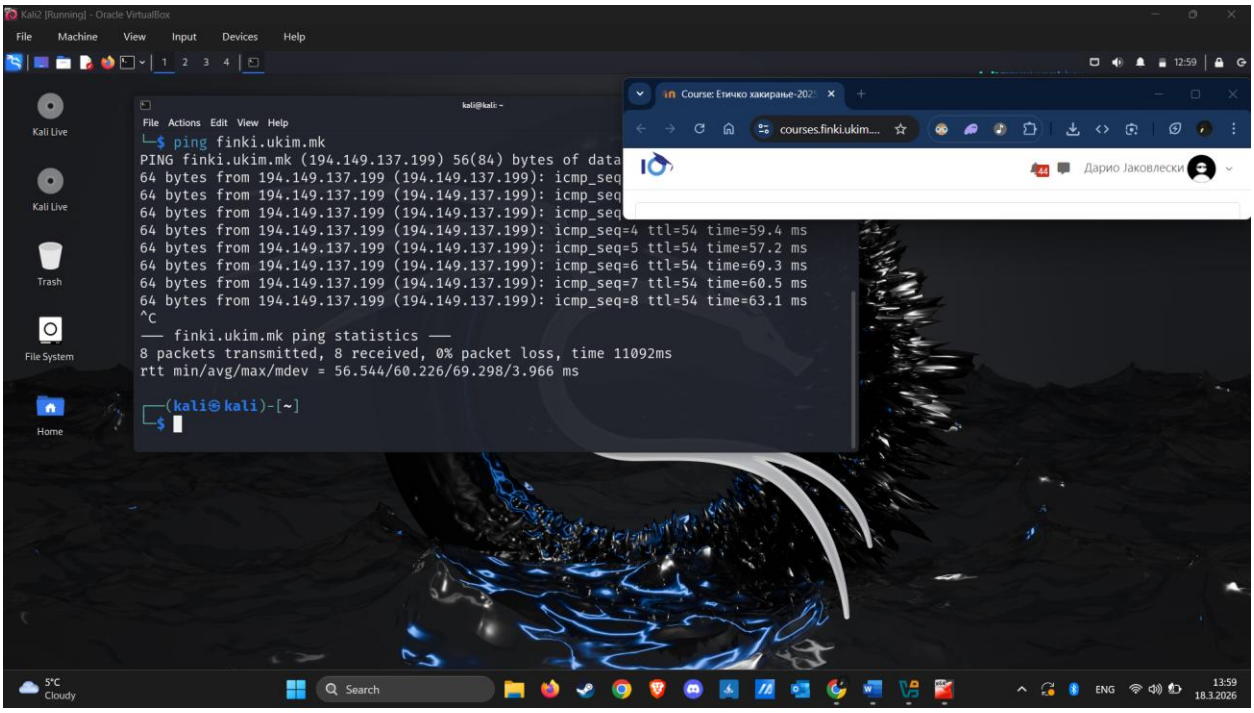
Текстуалните одговори давајте ги со црвена боја.

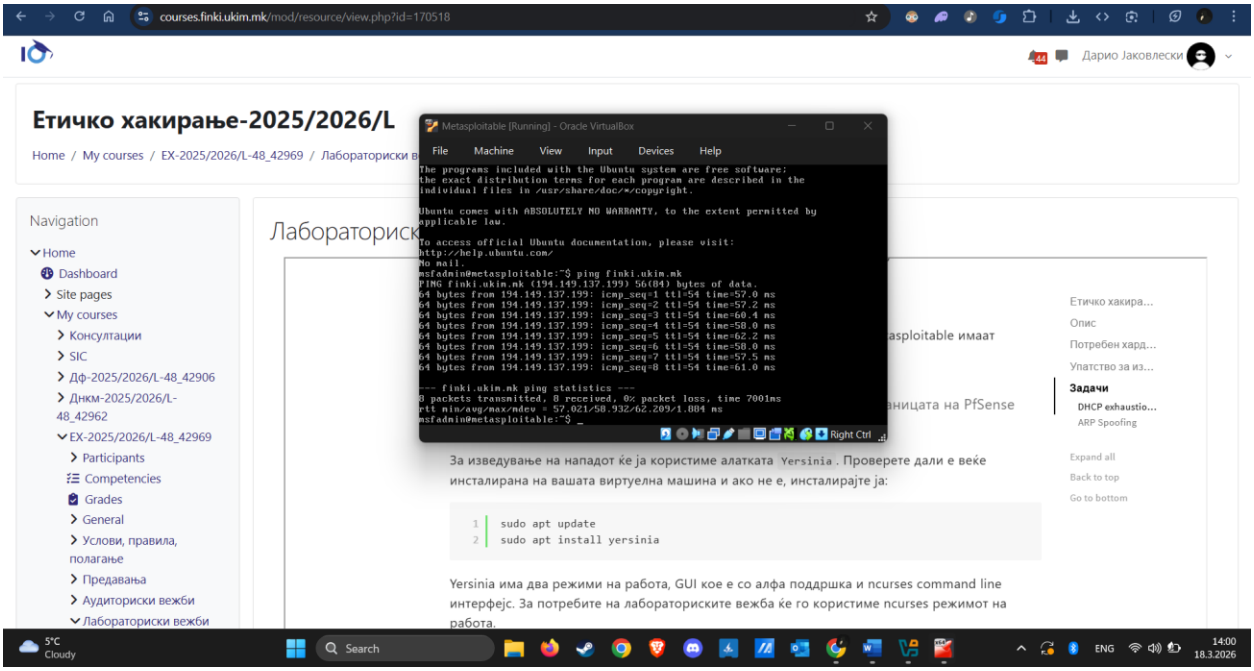
DHCP Exhaustion & DHCP Spoofing

Прашање 1: Поставете screenshot од Status->DHCP Leases страницата на PfSense и од ping finki.ukim.mk од Metasploitable и Kali машините.

Одговор 1:







Прашање 2: Кој аргумент треба да се предаде на командната линија за да се стартува Yersinia во интерактивен ncurses режим на работа?

Одговор 2:

The argument is -I (capital i for Interactive)

Прашање 3: Наведете ги keyboard shortcuts за следниве активности:

a) Излез од Yersinia
b) Стопирање на сите активни напади
c) Менување на разгледуваниот протокол
d) Започнување на напад

Одговор 3:

a) Излез од Yersinia:
b) Стопирање на сите активни напади:
c) Менување на разгледуваниот протокол:
d) Започнување на напад:

Action	**Shortcut**
Quit Yersinia	q
Stop all attacks	K
Change protocol	g (go to protocol)
Launch attack	x

Прашање 4: Пред да продолжите понатаму, размислете и опишете начини на кои можеме да се осигураме дека новите машини, жртви, со сигурност ќе ја прифатат DHCP OFFER пораката од Yersinia, а не од PfSense.

Одговор 4:

Прво исцрпување на DHCP: Преплавете го легитимниот PfSense DHCP сервер со лажни DISCOVER пакети за да му снема IP адреси. Ако PfSense нема повеќе IP адреси за да понуди, само лажниот сервер може да одговори.

Напад за ослободување на DHCP: Да го натераме PfSense да ги ослободи сите тековни дадени адреси, а потоа да се дејствува побрзо отколку што може повторно да понуди.

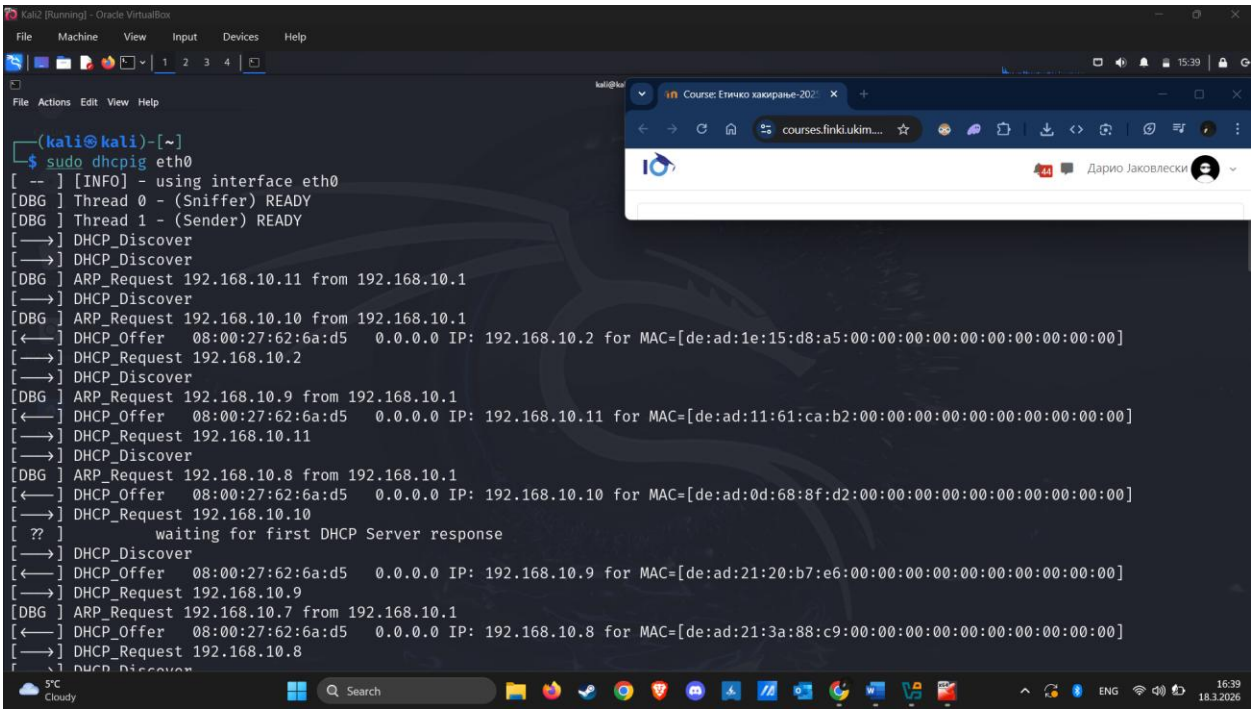
Прашање 5: Опишете ги со зборови чекорите за изведување на ваквиот DHCP Release напад во Yersinia и поставете слики од екранот за конфигурација и од извршувањето на нападот. Дали во главниот Yersinia прозорец се појави информација за некои пакети? Што можеме да дознаеме од нив?

Одговор 5:

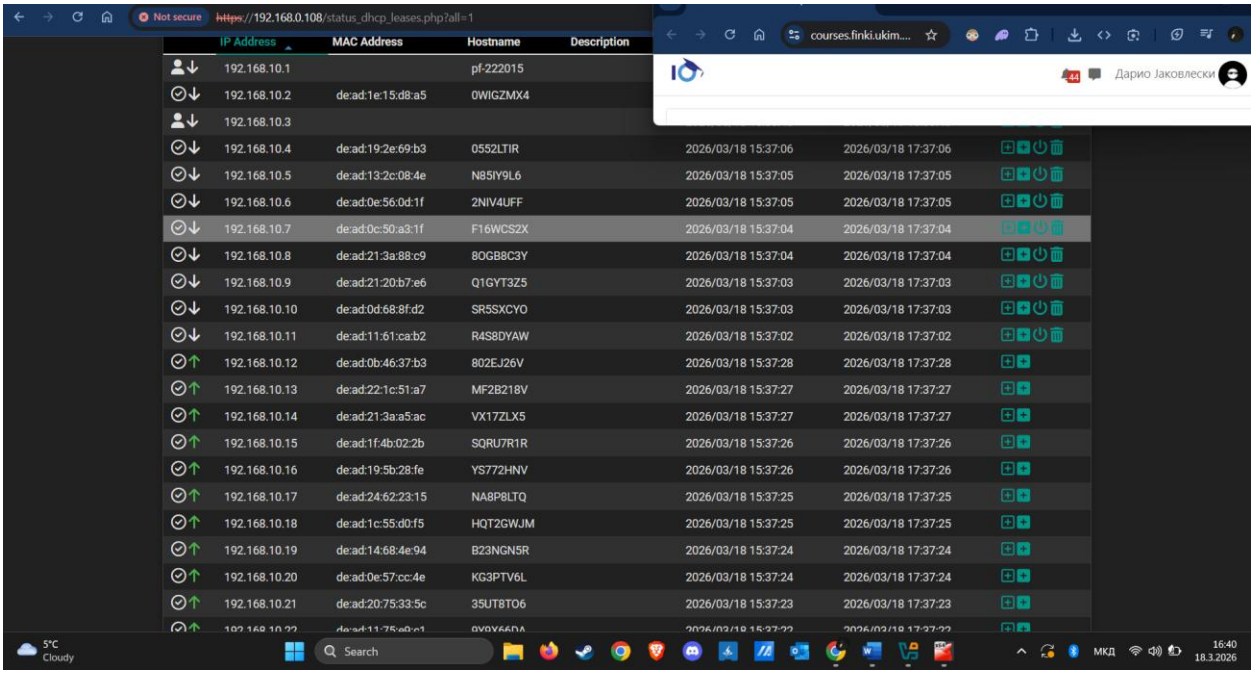
Адресите ги исчистив рачно преку pfsense so clear all dhcp leases бидејќи yersinia заради некоја причина не сакаше да почне со attack (dhcp relese)

Прашање 6: Опишете ги со зборови чекорите за изведување на DHCP DISCOVER напад во Yersinia и поставете слики од екранот за конфигурација и од извршувањето на нападот. Дали во главниот Yersinia прозорец се појави информација за некои пакети? Што можеме да дознаеме од нив?

Одговор 6:

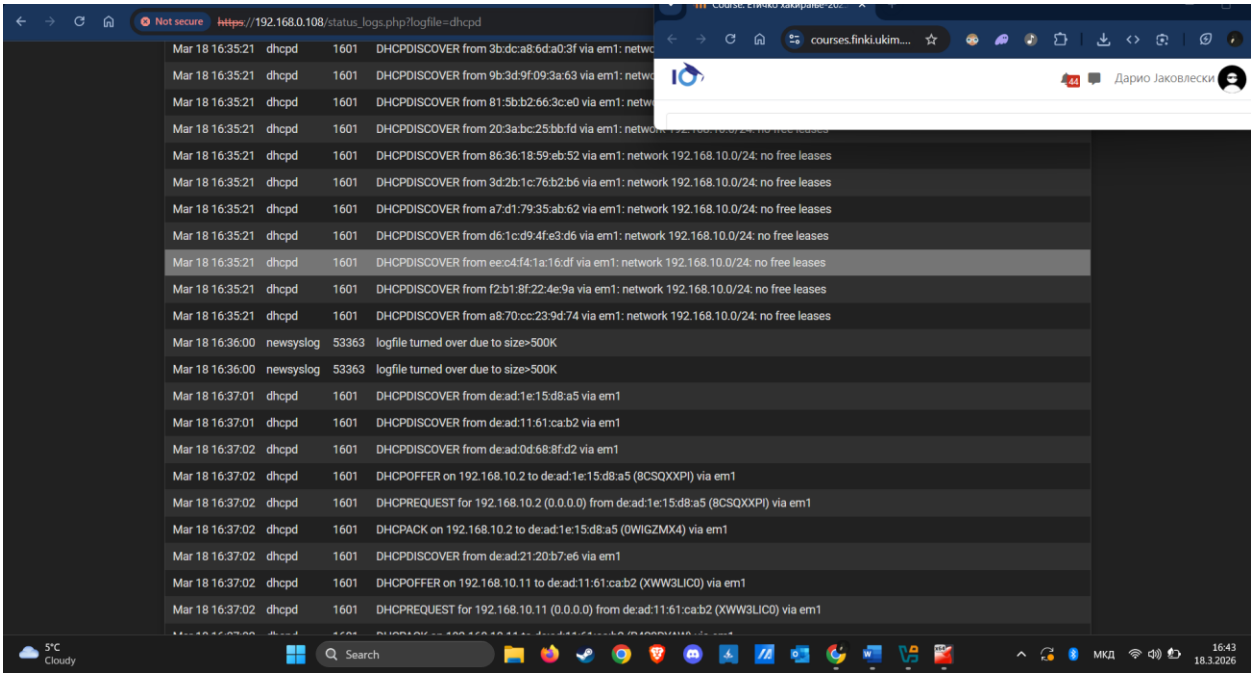


Наместо yersenia искористив друга алатака dhcpig за да ги пополнам адресите бидејќи со yersenia едноставно не сакаше да ги пополнит.



Прашање 7: Дали забележувате некакви интересни пораки во DHCP логот? Кое е нивното значење? Дадете кратко објаснување и поставете слика

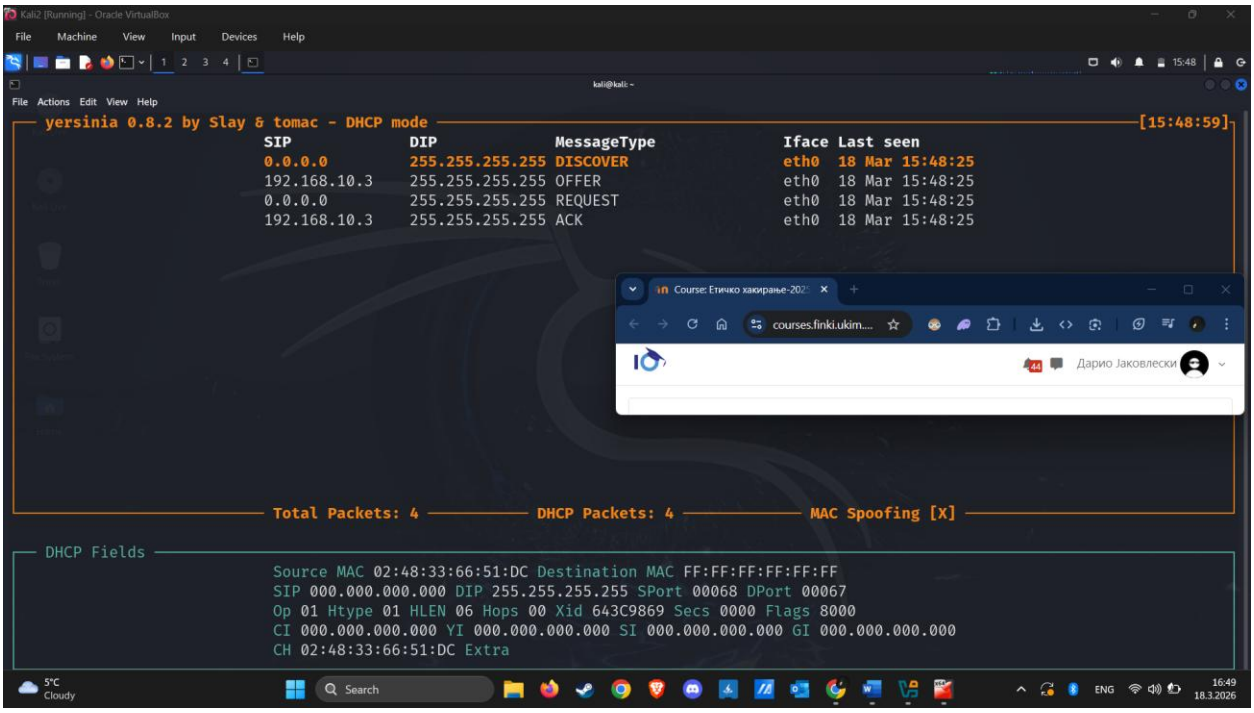
Одговор 7



Откако се пополи rangot на ип адреси во логовите стои no free leases што значи успешно ги пополнивме сите адреси.

Прашање 8: Опишете ги со зборови чекорите за покренување на лажниот DHCP сервер во Yersinia и поставете слики од екранот за конфигурација и од извршувањето на нападот.

Одговор 8:

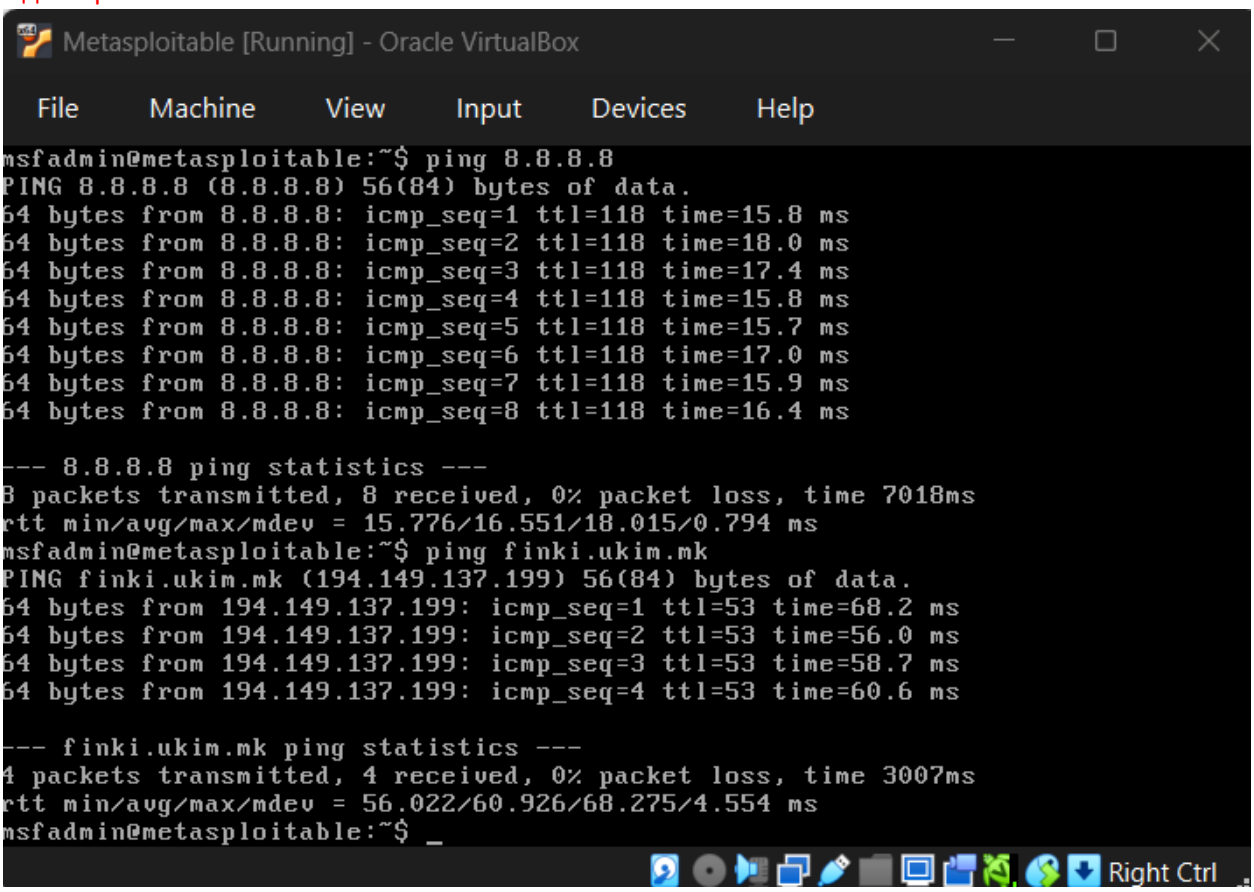


Прашање 9: Проверете дали Metasploitable виртуелната машина доби IP адреса од опсегот кој го дефиниравте при конфигурирањето на Yersinia во претходниот чекор и дадете одговор придружен со слика. Дополнително, поставете и слика од главниот прозорец на Yersinia каде што сега би требало да има фатено неколку DHCP пораки.

Одговор 9: Da Metasploitable доби адреса од yersinia.

Прашање 10: Дали ping-от од Metaspolitable виртуелната машина беше успешен? Поставете слика.

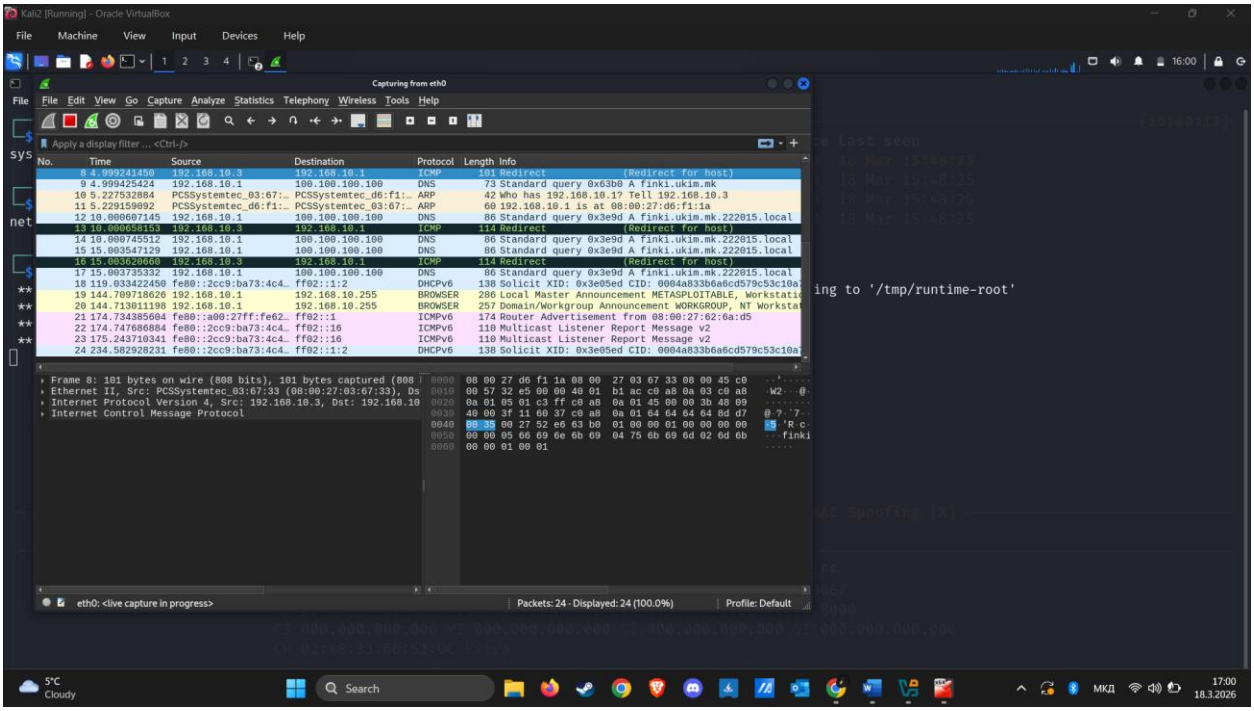
Одговор 10:



Пингот е успешен.

Прашање 11: Дали е целосно успешно фаќањето на сообраќајот? Што гледате во Wireshark? Поставете слика од Wireshark прозорецот. Успевате ли да ги видете и ICMP Echo Request и ICMP Echo Response пораките? Зошто?

Одговор 11:



ICMP Echo барањата одат: Metasploitable → Kali → PfSense → Internet. Но, ICMP Echo одговорите се враќаат во PfSense и одат директно во Metasploitable (бидејќи PfSense ја знае вистинската IP адреса на Metasploitable), целосно заобиколувајќи го Kali. Значи, во Wireshark гледате барања, но не и одговори.

Прашање 12: Дадете идеи за надминување на проблемот.

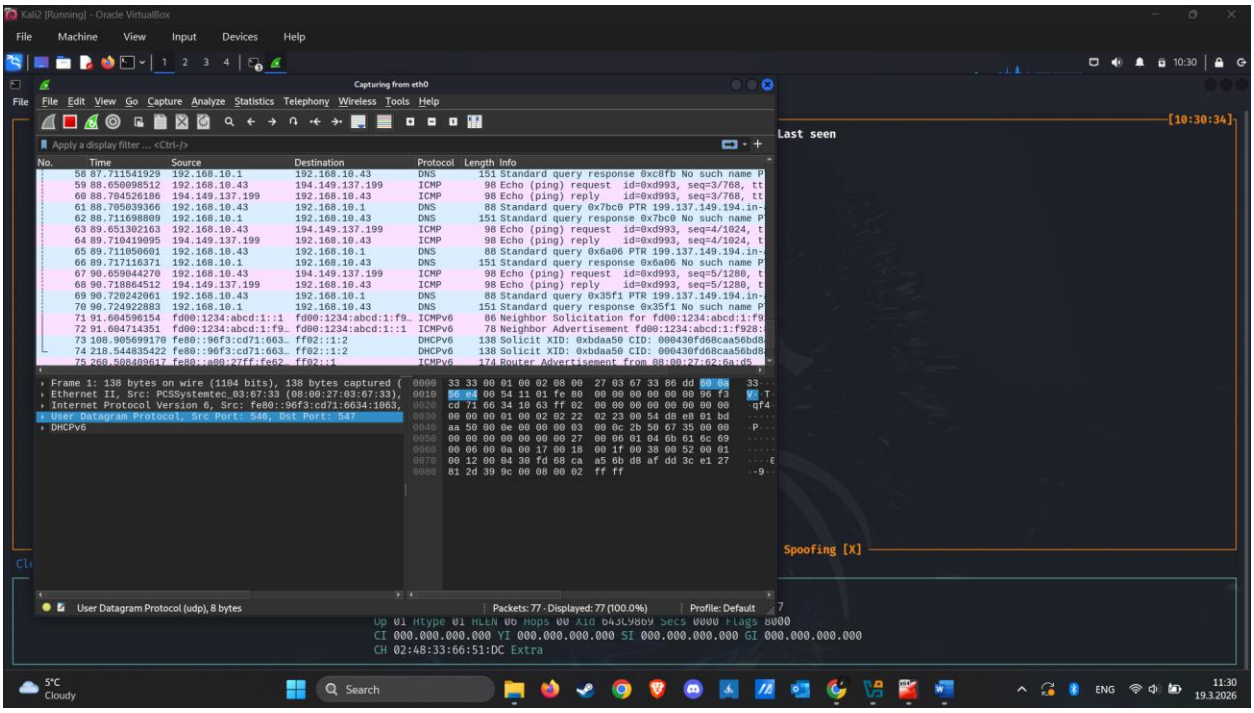
Одговор 12:

Конфигурирајте го source NAT (masquerade) на Kali, така што вистинскиот gateway мисли дека барањата потекнуваат од Kali, принудувајќи ги одговорите назад преку Kali

Поставете соодветно правило за рутирање кое го пренасочува сообраќајот на одговорот преку Kali

Прашање 13: Пробајте да го извршите уште еднаш ping-от од Metasploitable виртуелната машина. Дали сега можете да ги видите и request и response во Wireshark? Поставете слика и дадете објаснување зошто.

Одговор 13:

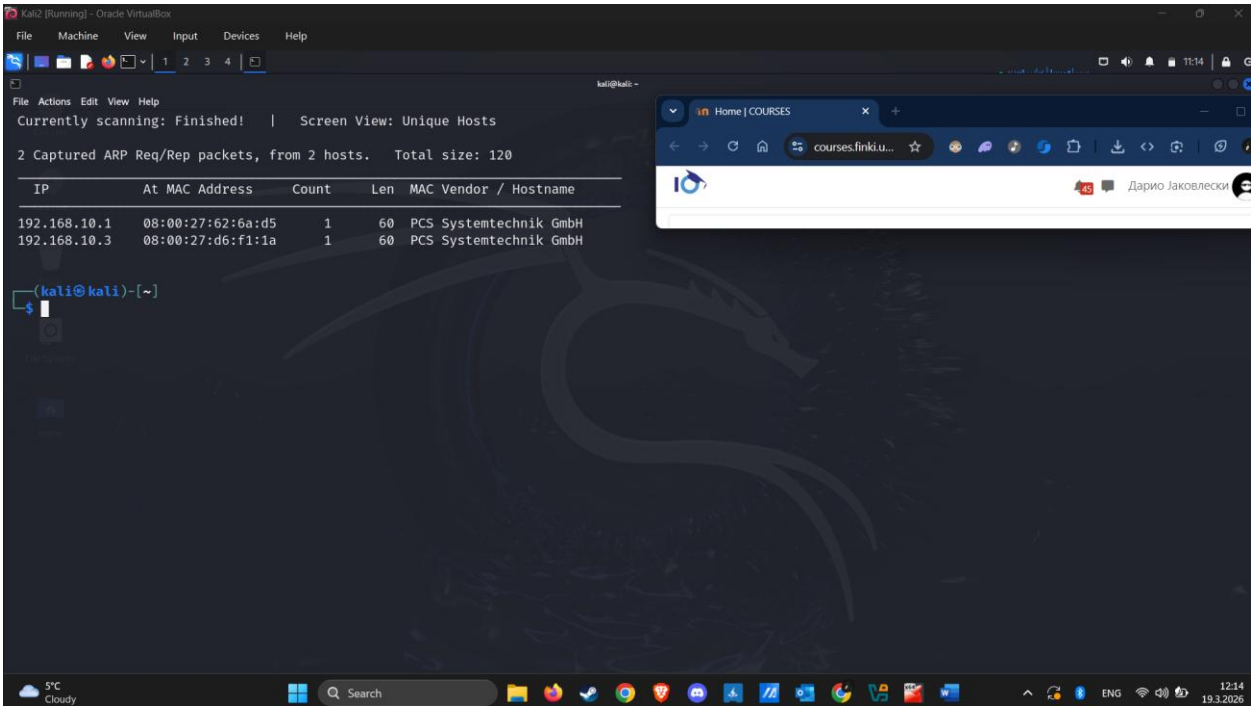


По додавањето на правилото NAT, Wireshark ќе ги прикаже и ICMP Echo Requests И Replies. Сега извршуваме целосен напад Man-in-the-Middle. Kali ја препишува изворната IP адреса на пакетите на Metasploitable на сопствената IP адреса на Kali пред да ги пренасочи. PfSense/internet ги гледа барањата од Kali, па одговорите се враќаат до Kali, кој потоа ги пренасочува до Metasploitable. Сега Kali ги гледа двете насоки на сообраќај.

ARP Spoofing

Прашање 1: Изведете скенирање на IP опсегот кој го користите за вашата Internal мрежа. Кој аргумент треба да го предадете на netdiscover за вакво „таргетирано“ скенирање на одреден опсег? Напишете ја целата команда и поставете слика од резултатите на скенирањето.

Одговор 1:



netdiscover -r 192.168.10.0/24

-r аргументот значи да се скренира целиот опсег на дадената мрежа

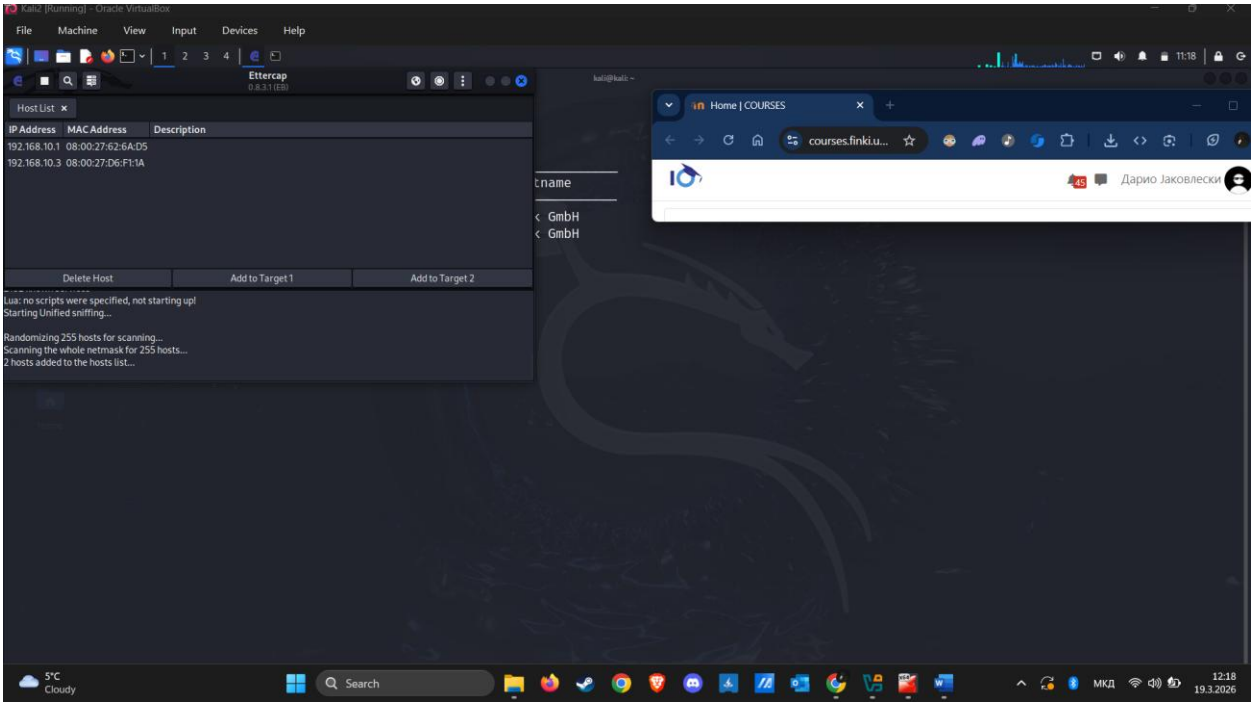
Прашање 2: Дали можете да претпоставите која од откриените IP адреси припаѓа на Metasploitable машината? Наведете ја и проверете ја вашата претпоставка со извршување на ip а во Metaspolitable виртуелната машина.

Одговор 2:

Во нашио случај е лесно да се види која е адресата,бидејќи немамо многу хостови. Таа е 192.168.10.03

Прашање 3: Споредете ги добиените резултати од Ettercap од екранот Hosts Listco оние од Netdiscover. Дали и двете алатки успеаја да ја детектираат Metasploitable виртуелната машина? Поставете слика од излезот од Ettercap.

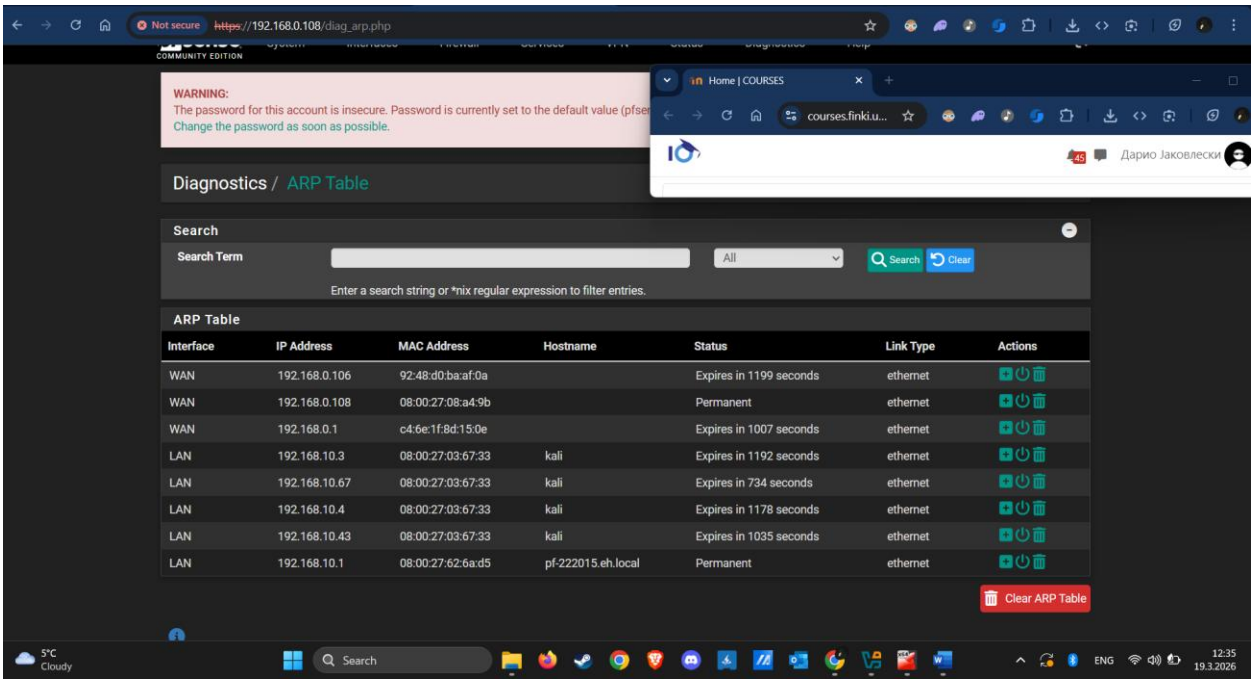
Одговор 3:



Да и двете алатки успеаа да ја најдат.

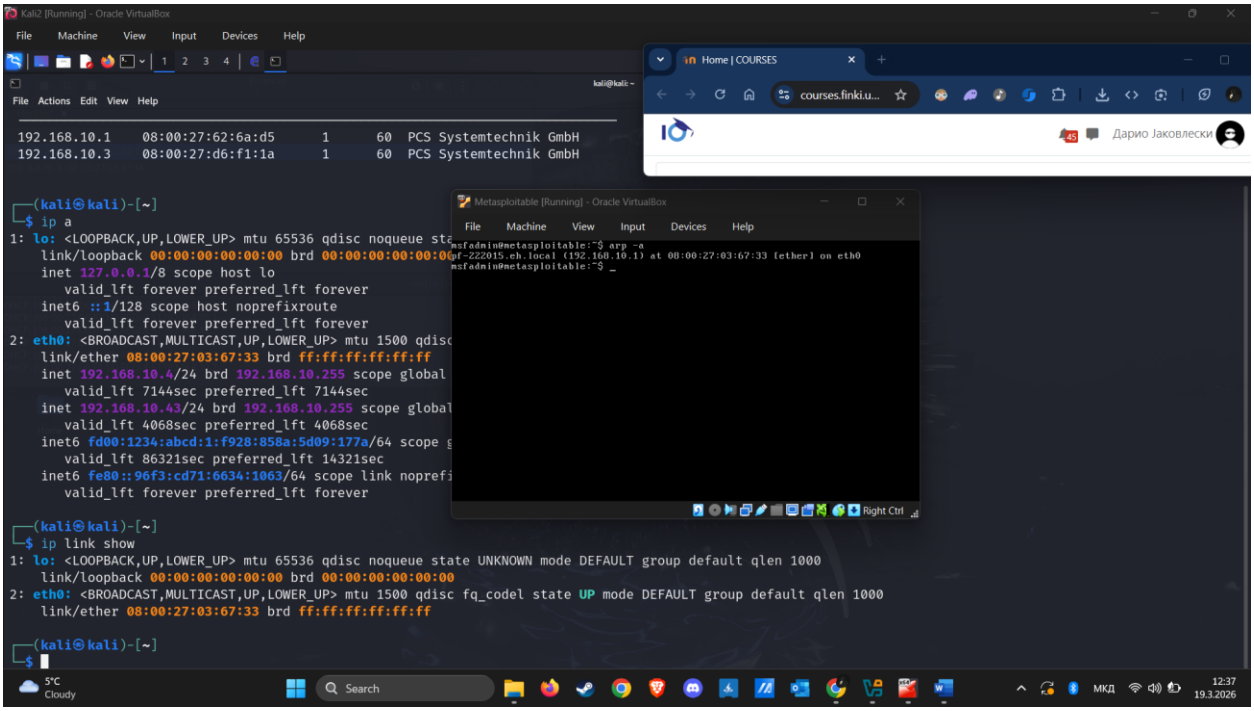
Прашање 4: Дали е успешен ARP нападот? Образложете и поставете слика од PfSense ARP Table.

Одговор 4:



Нападот е успешен бидејќи сега ип адресата на matasploitable и мапирана на mac адресата од kali .

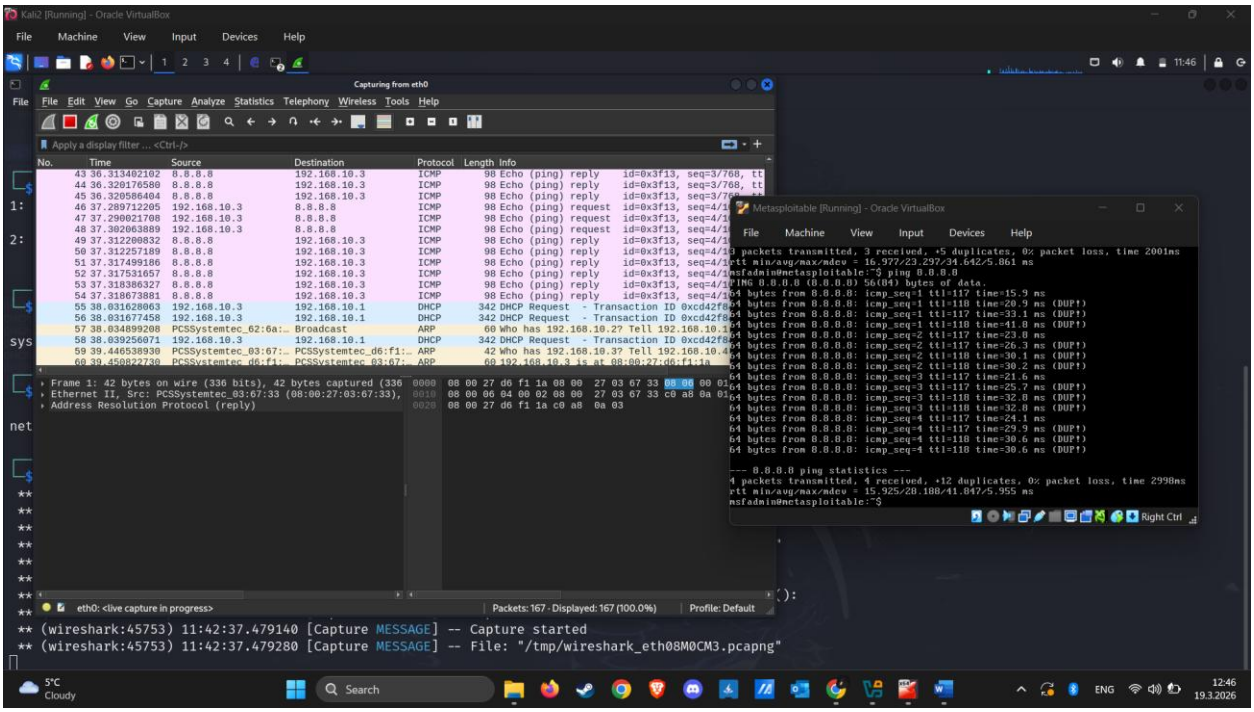
Исто и во metasplotable,ip адресата на pfsense е мапирана на mac од kali



Прашање 5: Дали во Wireshark можете успешно да ги видите и барањата и одговорите? Зошто? Поставете слика од Wireshark прозорецот.

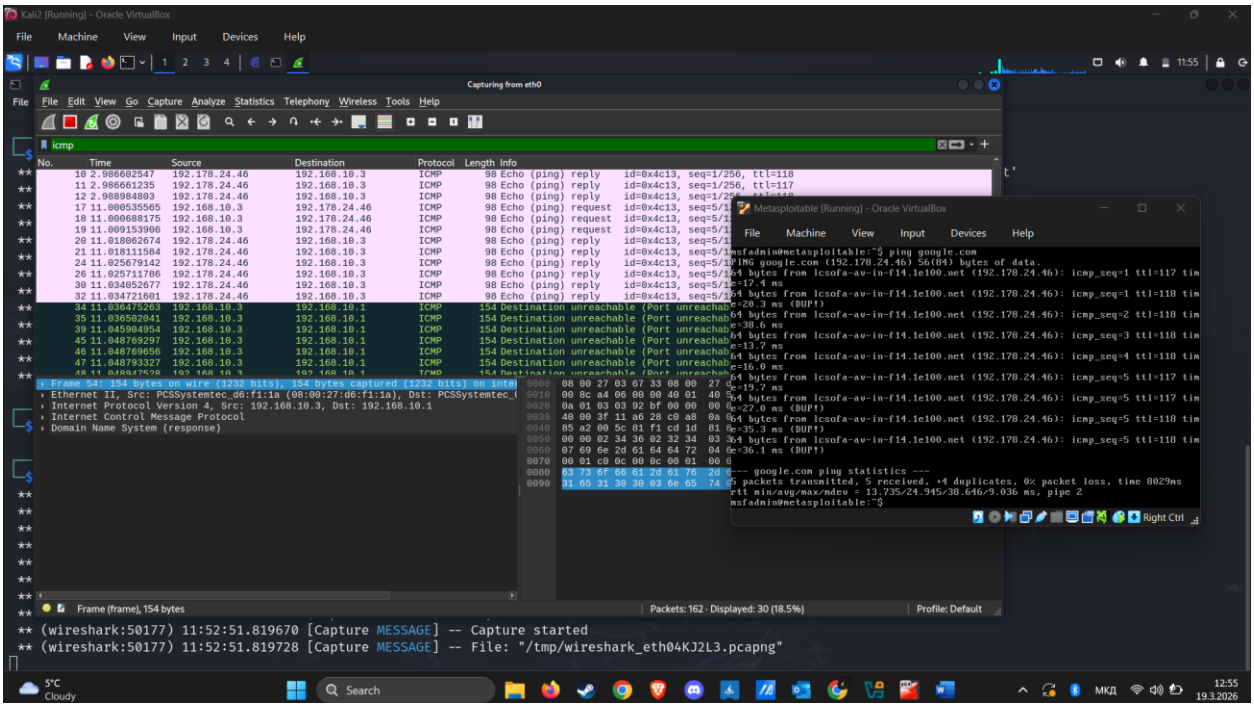
Одговор 5:

Гледаме и барањата и одговорите во Wireshark - бидејќи за разлика од сценариото за лажирање на DHCP, ARP труењето влијае на двата правци: Metasploitable испраќа до Kali (мислејќи дека е PfSense), а PfSense испраќа назад до Kali (мислејќи дека е Metasploitable).



Прашање 6: Дали сега можете да ги видите и барањата и одговорите? Поставете повторно слика од Wireshark прозорецот.

Одговор 6:

sudo iptables -I OUTPUT -p icmp --icmp-type redirect -o eth0 -j DROP

Drop ICMP Redirects